

EuropeanPay B.V.

Executive Cybersecurity GRC Assessment Report

Project 1 — FinTech Cybersecurity GRC Assessment

Assessment type	Simulated executive-level GRC assessment
Primary framework	ISO/IEC 27001:2022
Risk guidance	ISO/IEC 27005
Regulatory perspectives	GDPR, DORA and NIS2
Company	EuropeanPay B.V. — fictional
Headquarters	Amsterdam, Netherlands
Assessment date	October 2026
Prepared for	Executive Management and Board of Directors

Portfolio disclaimer: EuropeanPay B.V. is fictional. Risk ratings, control states and regulatory assessments are simulated and are not claims about a real organization.

Prepared by: Manideep Dommati | MBM Cybersecurity | Wittenborg University of Applied Sciences

1. Executive Decision Summary

EuropeanPay B.V. is a simulated European fintech organization with approximately 500 employees and 1 million active customers. Its services include SEPA payments, credit card acquiring, multi-currency wallets and merchant API integrations. The assessment combines the project's asset inventory, risk assessment, risk-treatment plan, ISO/IEC 27001 control mapping, GDPR gap assessment, NIS2 gap assessment, DORA assessment and third-party risk assessment.

The executive assessment shows a credible baseline of controls, while identifying remaining maturity priorities around customer PII protection, ransomware resilience, eKYC service continuity, phishing-resistant authentication, ICT third-party governance and regulatory evidence.

Executive position: The four assessed risks are reduced materially after treatment, but RSK-001 and RSK-003 remain at or above the project's treatment threshold and therefore require continued management attention.

Management decisions recommended

- Maintain executive ownership of RSK-001 through RSK-004 and require evidence-based closure.
- Prioritize cloud configuration guardrails, immutable backup capability, identity-provider resilience and phishing-resistant MFA.
- Strengthen DORA-oriented ICT risk, incident reporting, resilience testing and ICT third-party governance.
- Close GDPR and NIS2 process gaps through exercises, automation and governance.
- Refresh treatment dates before operational use because the workbook contains Q1–Q3 2026 targets while this report is dated October 2026.

2. Executive Risk Snapshot

The following figures reproduce the risk scores recorded in the Project 1 Risk Assessment workbook.

Risk ID	Risk scenario	Inherent	Residual	Reduction	Treatment
RSK-001	Unauthorized exfiltration of customer PII	20 — High	8 — Low	60%	Mitigate
RSK-002	Ransomware locking production cluster	15 — High	6 — Medium	60%	Mitigate
RSK-003	Third-party eKYC provider outage	16 — High	9 — Medium	44%	Transfer / Mitigate
RSK-004	Credential theft via spear phishing	20 — High	6 — Medium	70%	Mitigate

Project risk appetite: The treatment plan defines risks with scores ≥ 8 as requiring treatment. RSK-001 (8) and RSK-003 (9) therefore remain at the treatment threshold.

Executive interpretation

- RSK-001 has the highest residual exposure alongside RSK-003 and concerns sensitive customer PII.
- RSK-003 has the highest residual score and represents single-provider eKYC availability dependency.
- RSK-002 remains Medium because immutable backup and recovery capability is still a treatment priority.
- RSK-004 shows the strongest proportional reduction, but phishing-resistant authentication should remain continuously monitored.

3. Priority Risk Decisions

RSK-001 — Customer PII Exfiltration

The scenario concerns unauthorized exfiltration of customer PII caused by an unencrypted S3 bucket or exposed API keys. Existing controls include KMS encryption at rest and IAM role separation. Treatment: automated AWS Config guardrails to prevent public S3 exposure and enforce TLS 1.3.

Executive decision: Require evidence that preventive cloud guardrails are deployed, monitored and tested.

RSK-002 — Ransomware Against Production

The scenario involves ransomware locking the production cluster. Existing controls include AWS Backup and multi-region snapshots. Treatment: AWS S3 Object Lock for immutable backup storage.

Executive decision: Require a successful restore test, not merely confirmation that backups exist.

RSK-003 — eKYC Provider Outage

The scenario identifies single-provider dependency as the primary vulnerability. Existing controls are SLAs and monitoring. Treatment: secondary identity provider and tested API failover.

Executive decision: Approve the resilience business case and validate failover through testing.

RSK-004 — Spear-Phishing Credential Theft

The scenario identifies absence of FIDO2 hardware MFA as a vulnerability. Existing controls are TOTP MFA and security awareness. Treatment: FIDO2 security keys for cloud-accessing staff.

Executive decision: Maintain phishing-resistant MFA as mandatory for privileged and cloud access.

4. ISO/IEC 27001:2022 Governance Position

The ISO control mapping is structured as a Statement of Applicability-style assessment. Selected controls are recorded as applicable and implemented within the simulated scenario.

Control	Project status	Executive significance
A.5.15 Access control	Implemented	Protects logical access to customer and financial information.
A.5.23 Cloud services	Implemented	Relevant to AWS/Azure cloud-dependent operations.
A.8.28 Secure coding	Implemented	Important for payment-processing APIs.
A.7.1 Physical security perimeters	Excluded	Scenario assumes no physical data centre operated by EuropeanPay.

The mapping is a simulated portfolio assessment, not evidence of ISO/IEC 27001 certification. The next maturity step is to connect controls to objective evidence, owners, testing frequency and effectiveness results.

ISMS management priorities

- Maintain the defined ISMS scope covering people, processes, information assets, cloud infrastructure, applications, APIs, supporting technologies and relevant third-party interfaces.
- Maintain traceability from business context to assets, risks, treatments and controls.
- Develop an evidence register for policies, configurations, access reviews, tests, incidents, supplier reviews and management decisions.
- Use internal audit and management review to verify control effectiveness.

5. Regulatory Readiness Assessment

The project contains GDPR, DORA and NIS2 readiness/gap assessments. These are presented as portfolio assessments rather than legal certifications or definitive regulatory determinations.

GDPR

Area	Project status	Management action
Art. 6 — Lawfulness	Compliant	Maintain legal-basis records and RoPA.
Art. 35 — DPIA	Partially compliant	Update DPIA for automated/AI fraud-scoring activity.
Arts. 33/34 — Breach	Partially compliant	Conduct breach-notification tabletop exercise.
Arts. 15–21 — Data rights	Compliant	Automate AML-retention lock checks where appropriate.

DORA

Area	Gap identified	Remediation
ICT risk management	ISO ISMS needs explicit mapping to financial operational resilience metrics.	Align risk taxonomy with DORA RTS expectations.
ICT incident reporting	No complete reporting templates for major ICT incidents.	Create initial, intermediate and final report templates.
Resilience testing	Annual penetration testing; TLPT/red-team framework not yet executed.	Assess and schedule applicable TLPT/TIBER-aligned testing.
ICT third-party risk	Vendor list does not fully conform to the DORA information-register schema.	Create complete ICT services/subcontractor register.

NIS2

Area	Gap identified	Remediation
Incident handling	Project reporting process does not meet the 24-hour early-warning target.	Automate alert-to-SOC triage/reporting workflow.
Business continuity	Full failover test is annual.	Increase simulation cadence to twice per year.
Supply chain	Standard procurement contracts lack mandatory security requirements.	Add security clauses to vendor agreements.
Governance	Board cyber-risk training is not documented.	Implement annual Board cyber-risk training.

Regulatory caution: Actual applicability, entity classification and supervisory obligations must be confirmed against the organization's legal status and activities.

6. ICT Third-Party Risk

The third-party assessment identifies material dependencies for cloud infrastructure, identity verification, payment processing, CRM and monitoring.

Provider	Criticality	Inherent	Residual	Executive concern
AWS	Critical	High	Low	Cloud concentration and shared-responsibility oversight
Sumsb	Critical	High	Medium	Identity-service dependency and eKYC data
Adyen	Critical	High	Low	Payment-service availability and integration
Salesforce	Medium	Medium	Low	Customer/CRM access and data governance
Datadog	Critical	High	Medium	Monitoring/log availability and data exposure

The most important residual third-party concerns are Sumsb and Datadog, both recorded at Medium residual risk. The project recommends stronger ICT supplier governance, contractual security requirements, service monitoring and a more complete DORA-oriented information register.

Board-level supplier questions

- Which suppliers are genuinely critical to payment or customer-facing services?
- What is the recovery or exit strategy if a critical provider becomes unavailable?
- Are security, incident notification, audit and subcontractor requirements contractually enforceable?
- Is supplier concentration risk visible to executive management?

7. Executive Remediation Roadmap

The treatment plan contains Q1–Q3 2026 target dates. Because this report is dated October 2026, management should refresh those dates before using the roadmap operationally.

Priority	Action	Owner	Status recorded
1	AWS configuration guardrails; prevent public S3 exposure; enforce TLS 1.3.	Cloud Security Lead	In Progress
2	Immutable S3/Object Lock backup storage and recovery validation.	DevOps Manager	Planned
3	Secondary identity provider and API failover capability.	Product Manager	Proposed
4	FIDO2 security keys for staff accessing cloud environments.	CISO / IT Lead	Complete

Recommended management sequencing

- **Immediate:** Validate RSK-001 and RSK-002 control evidence, especially cloud guardrails and immutable backup/restore.
- **Near term:** Close the RSK-003 availability dependency through tested eKYC failover.
- **Continuous:** Verify RSK-004 FIDO2 coverage and monitor privileged/cloud-access exceptions.
- **Governance:** Integrate risk treatment with GDPR, DORA and NIS2 remediation trackers.
- **Assurance:** Establish recurring control testing, internal audit and management review.

8. Budget and Resource Allocation

For portfolio planning, the project proposes an indicative investment envelope of €150,000–€250,000. This is a scenario estimate, not actual EuropeanPay financial data.

Investment area	Purpose	Management rationale
GRC automation	Risk, compliance and evidence management	Improve traceability and executive reporting
Identity security	FIDO2/security keys and access controls	Reduce credential and privileged-access risk
External assurance	Audit/advisory and independent assurance	Validate ISMS and control maturity
Security/resilience testing	Penetration, failover and resilience testing	Demonstrate operational effectiveness
Third-party risk	Supplier assessment and monitoring	Reduce ICT supply-chain exposure
Incident readiness	Exercises and reporting workflows	Improve response and regulatory preparedness

9. Executive KPIs and KRIs

Metric	Executive purpose
Critical/high risks overdue	Shows remediation discipline and management escalation.
Residual risk above appetite	Shows remaining enterprise exposure.
MFA/FIDO2 coverage	Measures identity-security maturity.
Immutable-backup restore-test success	Measures recovery capability.
Critical suppliers assessed	Measures ICT third-party governance.
Major incidents and response times	Measures operational resilience.
DPIA/privacy actions overdue	Measures privacy governance.
DORA/NIS2 remediation completion	Measures regulatory readiness.
ISO control effectiveness	Measures whether controls operate as intended.

10. Board and Executive Decisions Required

Decision	Recommended position
Risk ownership	Confirm accountable owners for RSK-001 through RSK-004 and require evidence-based closure.
Cloud security	Continue investment in preventive configuration guardrails and cloud-control monitoring.
Resilience	Approve immutable backup and tested recovery for production workloads.
eKYC continuity	Approve secondary identity-verification capability and failover testing.
Identity security	Maintain FIDO2 as required phishing-resistant authentication for cloud access.
Third-party governance	Require critical ICT suppliers to meet enhanced security, incident and contractual requirements.
Regulatory readiness	Approve integrated GDPR/DORA/NIS2 remediation tracking and executive reporting.
ISMS maturity	Continue ISO/IEC 27001-aligned ISMS development with internal audit and management review.

11. Executive Conclusion

Project 1 demonstrates a complete cybersecurity GRC lifecycle for a simulated fintech organization: business context is translated into assets; assets are assessed against threats and vulnerabilities; risks are scored; treatments are assigned; ISO/IEC 27001 controls are mapped; regulatory gaps are identified; and third-party dependencies are evaluated.

The four assessed risks reduce from inherent scores of 15–20 to residual scores of 6–9. This demonstrates measurable risk reduction while showing that customer PII exposure and eKYC service continuity remain important management concerns.

From a C-suite perspective, the priority is now evidence and effectiveness: verify that controls operate, close the remaining Medium-level exposures where appropriate, strengthen ICT third-party resilience, and establish recurring management oversight.

Executive position: Continue the GRC program, prioritize evidence-based remediation, strengthen regulatory-readiness processes and mature the ISO/IEC 27001-aligned ISMS into a continuous management system.

12. Assessment Basis and Limitations

- EuropeanPay B.V. is fictional and all organizational characteristics are scenario assumptions.
- The assessment is not an ISO/IEC 27001 certification audit, penetration test, technical security audit or legal opinion.
- Risk scores and control states are based on the supplied Project 1 worksheets.
- Third-party certifications, contracts, data locations and actual control effectiveness have not been independently verified.
- Payment tokens are assumed; the scenario does not assume EuropeanPay stores complete raw cardholder data.
- GDPR, DORA and NIS2 applicability require confirmation against an actual organization's circumstances.
- The report should be updated whenever the underlying Numbers workbooks change.

Project 1 Evidence Set

Artifact	Purpose
Company Overview	Business context, technology, ISMS scope and organizational context
Asset Inventory	Information and associated asset identification
Risk Assessment	Inherent and residual risk scoring
Risk Treatment Plan	Treatment actions, owners, controls and status
ISO-27001 Control Mapping	Annex A applicability and implementation mapping
GDPR Gap Assessment	Selected privacy gaps and actions
NIS2 Gap Assessment	Cybersecurity governance and resilience gaps
DORA Assessment	ICT risk, incident, resilience and third-party readiness
Third-Party Risk	Critical supplier risk and residual exposure